Security Frameworks Overview of NIST, ISO 27001, and CIS Controls. Practical : Map security measures to a given framework.

Tasks

1. Pick any one app you use daily (such as Instagram, Zomato, or PhonePe) and list 5 security measures it likely uses to protect user data.

Ans.:-

Security Measures Used by PhonePe :-

I choose PhonePe, a commonly used digital payment app. It likely uses several security measures to protect user data and transactions:

1. **MPIN / App Lock** – Requires a PIN or authentication to access the account and perform sensitive actions.
2. **OTP Verification** – OTPs can be used to verify important account or login activities.
3. **Encryption** – User and transaction data is protected using encryption while being transmitted and stored.
4. **Device Binding** – The account can be linked to a registered mobile device to reduce unauthorized access.
5. **Transaction Monitoring** – Suspicious or unusual transactions can be detected and flagged to help prevent fraud.

Conclusion

PhonePe uses multiple layers of security such as PINs, OTPs, encryption, device security, and fraud monitoring to help protect users' personal and financial information.

**2. Choose either the NIST Cybersecurity Framework, ISO 27001, or CIS Controls. For each of the 5 security measures you listed in the previous task, map it to the most relevant category or control in your chosen framework.

Hint: For example, 'two-factor authentication' might map to 'Access Control' in CIS or 'Protect' in NIST.**

Ans.:-

Mapping 5 Security Measures to NIST Cybersecurity Framework :-

No.	Security Measure	NIST CSF Category	Explanation
1	Two-Factor Authentication (2FA)	Protect – Identity Management, Authentication & Access Control (PR.AA)	2FA adds an extra verification step and prevents unauthorized account access.
2	Check Email Headers	Identify – Risk Assessment (ID.RA)	Checking email headers helps identify suspicious senders and phishing attempts.
3	Use Strong & Unique Passwords	Protect – Identity Management, Authentication & Access Control (PR.AA)	Strong passwords reduce the risk of password guessing and account compromise.
4	Email Spam/Phishing Filters	Protect – Technology Infrastructure Resilience (PR.IR)	Email filtering helps detect and block malicious or phishing messages before they reach users.
5	Security Awareness Training	Protect – Awareness & Training (PR.AT)	Training helps users recognize phishing emails, suspicious links and social-engineering attacks.

The NIST Cybersecurity Framework helps organizations identify risks, protect systems, detect threats, respond to incidents, and recover from attacks. The five security measures above mainly support the Identify and Protect functions, especially authentication, email security, and user awareness.

3. Given this scenario: A new food delivery app wants to prevent unauthorized access, protect payment info, and ensure customer privacy. Select 3 controls from the CIS Controls framework that would address these concerns and explain how each control helps.

Ans.:-

CIS Controls for a Food Delivery App :-

NO.	CIS CONTROL	HOW IT HELPS
1	**CIS Control 6 – Access Control Management**	Ensures only authorized users and employees can access the app, customer accounts, and administrative systems. Strong authentication and proper permissions reduce unauthorized access.
2	**CIS Control 3 – Data Protection**	Protects sensitive information such as customer details, addresses, and payment information through encryption, secure storage, and proper data handling.
3	**CIS Control 14 – Security Awareness and Skills Training**	Trains employees to recognize phishing, social engineering, and other security threats that could expose customer information or payment data.

CIS Control 6 prevents unauthorized access, CIS Control 3 protects customer and payment data, and CIS Control 14 helps employees avoid security mistakes and phishing attacks. Together, these controls improve the food delivery app's security, payment protection, and customer privacy.

**4. Create a comparison table with three columns (NIST, ISO 27001, CIS Controls) and list 3 unique features or strengths of each framework based on your research.

Hint: Focus on what makes each framework different or especially useful for certain organizations.**

Ans.:-

Comparison of NIST, ISO 27001, and CIS Controls :-

NIST Cybersecurity Framework	ISO 27001	CIS Controls
1. Provides a flexible cybersecurity framework that can be adapted to different organizations.	1. Provides an internationally recognized standard for information security management.	1. Provides prioritized and practical security controls that organizations can implement directly.
2. Uses five main functions: Identify, Protect, Detect, Respond, and Recover.	2. Focuses on establishing an Information Security Management System (ISMS).	2. Focuses on specific technical and organizational actions to reduce common cyber threats.
3. Useful for organizations that want to assess and improve cybersecurity risk management without requiring certification.	3. Organizations can obtain ISO/IEC 27001 certification, which demonstrates their commitment to information security.	3. Especially useful for organizations that need a simple, actionable starting point for cybersecurity.

NIST is best for flexible cybersecurity risk management, ISO 27001 is best for organizations wanting a formal and certifiable information security management system, while CIS Controls is best for practical and prioritized security implementation.

5. Use ChatGPT or another AI tool to generate a checklist of 5 security actions a small e-commerce startup should take according to the ISO 27001 framework. Copy the AI's response and briefly comment on whether you agree with each item and why.

Ans.:-

ISO 27001 Security Checklist for a Small E-Commerce Startup :-

No.	*AI-Generated Security Action*	*My Comment*
1	Create an Information Security Policy – Establish clear rules for protecting company, customer, and payment information.	Agree. A security policy gives employees clear guidelines for handling sensitive information and reduces security mistakes.
2	Control User Access – Give employees only the access they need and use strong passwords and multi-factor authentication (MFA).	Agree. Limiting access and using MFA reduces the chance of unauthorized access to customer and business data.
3	Protect and Encrypt Sensitive Data – Encrypt sensitive customer and payment information during storage and transmission.	Agree. Encryption helps protect data even if it is intercepted or accessed by an unauthorized person.
4	Perform Regular Risk Assessments and Security Reviews – Identify security risks, vulnerabilities, and potential threats regularly.	Agree. Regular assessments help the startup discover weaknesses early and take action before an incident occurs.
5	Create an Incident Response and Backup Plan – Maintain secure backups and establish procedures for detecting, reporting, and responding to security incidents.	Agree. A response plan helps the company recover quickly from incidents such as ransomware, data breaches, or system failures.

I agree with all five actions because they address important areas of an ISO 27001-based information security management approach: policies, access control, data protection, risk management, and incident recovery. These measures are especially important for a small e-commerce startup because it handles customer information and payment-related data.